



IDATA CHILE · INFORME DE DIAGNÓSTICO

Análisis de seguridad — morenoycia.cl

Diagnóstico de prospección · modo pasivo

Versión	1.0
Fecha	27-07-2026
Emitido por	IDATA Chile
Contacto	https://idatachile.com

Objetivo: https://morenoycia.cl **Fecha del escaneo:** 2026-07-27 04:06 UTC **Modo:** pasivo (prospección, sin autorización — Ley 21.459 respetada) **Herramienta:** IDATA Sentinel, módulos vuln , assets , privacy **Verificación:** todos los hallazgos fueron contrastados manualmente contra el objetivo, DNS-over-HTTPS, Certificate Transparency y el repositorio oficial de WordPress.

1. Veredicto

La postura de seguridad es **razonable en lo técnico y deficiente en lo normativo**. La infraestructura está bien mantenida: TLS 1.3 correcto, WordPress y WooCommerce en su última versión, xmlrpc.php bloqueado y una superficie de ataque genuinamente pequeña.

El problema está en otro lado. **El sitio opera una tienda WooCommerce activa y tres formularios de captación, y no publica ninguna política de privacidad**. Para un estudio jurídico cuyos servicios incluyen la eliminación de registros en DICOM, Equifax y el Boletín de Informaciones Comerciales — es decir, que trata historiales de deuda de personas naturales — esa omisión no es un detalle de forma.

Perfil de riesgo del cliente: el sitio capta consultas jurídicas por formulario libre y vende un producto de reserva por WooCommerce. Los datos que recibe son de identificación, contacto y situación financiera o judicial del titular. Bajo la Ley 21.719 eso exige información previa, base de licitud declarada y un canal para ejercer derechos. Hoy no hay ninguno de los tres.

2. Superficie de ataque

Inventario reconstruido desde Certificate Transparency y verificado por resolución DNS y consulta HTTP a cada host:

HOST	DNS	RES-PUESTA	OBSERVACIÓN
morenoycia.cl	34.174.15.135	200	Sitio productivo, WordPress + WooCommerce
www.morenoycia.cl	34.174.15.135	301 → apex	Correcto
ftp.morenoycia.cl	34.174.15.135	sin HTTPS	Servicio FTP
mail.morenoycia.cl	34.174.15.135	sin HTTPS	Alias de correo
cpanel. webmail. webdisk. cpca-lendars. cpcontacts. pop. smtp.	no resuelven	—	Certificados históricos de un hosting cPanel anterior

Este es el punto fuerte del sitio. Los siete subdominios de la familia cPanel que aparecen en los registros de Certificate Transparency **ya no resuelven**: son residuo de un proveedor anterior. Hoy el dominio está en SiteGround (ns1/ns2.siteground.net) y solo expone el sitio web. No hay paneles de administración ni entornos de prueba accesibles desde Internet.

Sin CNAME colgante, tampoco hay riesgo de subdomain takeover. Los nombres quedan como constancia de activos retirados.

3. Hallazgos

3.1 — ALTO · Sin política de privacidad, con tienda y formularios activos

No existe ningún enlace a política de privacidad, tratamiento de datos, términos ni cookies. Verificado en la portada, en /contacto/ y en /consulta-juridica/ : cero coincidencias de texto.

Al mismo tiempo, el sitio capta datos personales por tres vías:

VÍA	DATOS
Formulario Piotnet (portada, /contacto/ , /consulta-juridica/)	Nombre, correo, mensaje libre y campo oculto remote_ip
Tienda WooCommerce	Producto "Reserva"; el flujo de compra implica datos de facturación y cuenta de cliente
flexible-checkout-fields	Plugin de campos personalizados de checkout: hay recolección adicional configurada

El campo `remote_ip` es relevante: el formulario **registra deliberadamente la dirección IP del visitante** y la envía junto al resto. Es un dato personal y hoy se recoge sin informarlo.

El mensaje libre de una consulta jurídica contendrá el problema legal del titular. Para un estudio que ofrece limpieza de DICOM, eso significa datos de deuda y morosidad: información financiera con estándar reforzado.

Corrección: publicar la política de privacidad y enlazarla desde el pie de todo el sitio; añadir aviso y casilla de consentimiento en los tres formularios; declarar la finalidad, el plazo de conservación y el canal de ejercicio de derechos. Si el checkout de WooCommerce está operativo, cubrirlo también.

3.2 — MEDIO · Enumeración de usuarios por dos vías distintas

El nombre de usuario del administrador está publicado por partida doble:

VÍA	RESULTADO
GET /wp-json/wp/v2/users	[{"id": 1, "name": "lgsalcedo", "slug": "lgsalcedo"}]
GET /wp-sitemap-users-1.xml	https://morenoycia.cl/author/lgsalcedo/

`id: 1` es la cuenta administradora original. El sitemap de usuarios está anunciado en `wp-sitemap.xml`, que a su vez está declarado en `robots.txt`: cualquier rastreador lo encuentra sin buscarlo.

Atenuante importante: `xmlrpc.php` devuelve **403**, lo que cierra el vector de fuerza bruta amplificada por `system.multicall`. Queda `wp-login.php` como superficie de ataque directa.

Corrección: restringir `wp-json/wp/v2/users` a usuarios autenticados, desactivar el sitemap de usuarios, y forzar 2FA junto a limitación de intentos en `wp-login.php`.

3.3 — MEDIO · Correo: registros publicados pero sin aplicación

```
morenoyca.cl      TXT      v=spf1 +a +mx include:morenoyca.cl.spf.auto.dnssmarthost.net
~all
_dmarc.morenoyca.cl TXT      v=DMARC1; p=none; aspf=r; adkim=r;
```

- `p=none` — DMARC solo monitorea. Un correo que suplanta al dominio se entrega igual.
- **Sin `rua=`** — no se recibe ni siquiera el reporte agregado. La política está publicada pero nadie puede leer sus resultados: es monitoreo sin monitor.
- `~all` (softfail) en lugar de `-all`.
- `+a +mx` autoriza a enviar correo al servidor web y a todos los MX.
- DKIM `default._domainkey` está publicado vía `dnssmarthost.net`, con clave RSA de 1024 bits — por debajo del estándar actual de 2048.

Suplantar el dominio de un estudio jurídico para escribir a sus clientes es un vector de fraude directo. Hoy nada lo impide.

Corrección: añadir `rua=` primero, revisar reportes durante 2-4 semanas, y luego subir a `p=quarantine` y `p=reject`; cambiar `~all` por `-all`; quitar `+a +mx`; rotar DKIM a 2048 bits.

3.4 — MEDIO · Transferencias internacionales sin declarar

La portada carga dos servicios de Google en cada visita, antes de cualquier consentimiento:

SERVICIO	RECURSO	QUÉ TRANSFIERE
Google Maps (iframe)	<code>www.google.com/maps/embed?pb=...</code>	IP, User-Agent y cookies de Google del visitante
Google Fonts	<code>fonts.googleapis.com/css?family=Open+Sans Source+Sans+Pro</code>	IP + User-Agent en cada carga

El iframe de Maps es el más intrusivo: no es una hoja de estilos, es un documento completo de Google que se ejecuta dentro de la página. Ambos se resuelven sin perder funcionalidad — las fuentes se autoalojan, y el mapa puede sustituirse por una imagen estática enlazada a Google Maps, que solo transfiere datos si el visitante hace clic.

3.5 — MEDIO · Cabeceras de seguridad ausentes

Confirmadas como faltantes en / : HSTS, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Cross-Origin-Opener-Policy, Cross-Origin-Resource-Policy y Permissions-Policy.

La ausencia de CSP y X-Frame-Options pesa más aquí que en un sitio informativo: **con WooCommerce activo hay un flujo de checkout**, y ahí el clickjacking y la inyección de contenido tienen consecuencias económicas directas, no solo reputacionales.

`/.well-known/security.txt` tampoco está publicado.

3.6 — BAJO · Versiones de plataforma expuestas

COMPONENTE	VERSIÓN	ESTADO
WordPress	7.0.2	Al día
WooCommerce	10.9.4	Al día
Click to Chat	4.41	Al día
Oxygen Builder	4.9.7	Premium — no verificable contra el repositorio público
Piotnet Forms Pro	2.1.42	Premium — no verificable contra el repositorio público

Todo lo verificable está actualizado, lo que habla bien del mantenimiento. La exposición de versión en la meta `generator` y en los parámetros `?ver=` es de riesgo bajo mientras eso se mantenga; se convierte en una señal de targeting el día que salga un CVE para alguna de esas versiones.

Los dos plugins premium quedan como punto ciego: conviene confirmar con el cliente que tienen licencia vigente y reciben actualizaciones.

3.7 — Informativo · Plugins visibles solo por la API REST

La API REST anuncia 22 espacios de nombres, varios de plugins que no aparecen en el HTML:

```
wc/v3, wc/v2, wc/v1, wc/store, wc/store/v1, wc/private, wc/pos/v1/catalog,
wc-admin, wc-analytics, wc-telemetry, wc-admin-email, wccom-site/v3,
flexible-checkout-fields/v1, ailwm/v1, jetpack/v4, cptui/v1, sg-ai-studio,
wp/v2, wp-abilities/v1, wp-site-health/v1, wp-block-editor/v1, oembed/1.0
```

Dos merecen atención en una auditoría autorizada:

- **ailwm/v1 — All-in-One WP Migration.** Genera archivos de respaldo del sitio completo. Si quedan alojados en una ruta accesible, un respaldo contiene la base de datos entera: usuarios, hashes de contraseña y todos los datos de clientes. **No se comprobó** — hacerlo exige modo auditoría.
- **wc/pos/v1/catalog** — hay un punto de venta conectado a la tienda, lo que amplía el tratamiento de datos más allá del sitio web.

La tienda está viva: `wc/store/v1/products` devuelve un producto ("Reserva", 0 CLP). Es una tienda mínima, pero operativa, con las rutas de cuenta de cliente y checkout que eso implica.

3.8 — Puntos correctos, para dejar constancia

- **TLS 1.3** con cadena confiable y certificado vigente.
 - `xmlrpc.php` **bloqueado (403)** — cierra el vector de fuerza bruta amplificada.
 - **WordPress y WooCommerce en su última versión.**
 - `robots.txt` **bien configurado**: excluye `wc-logs/` , `woocommerce_uploads/` y `woocommerce_transient_files/` , que son exactamente los directorios sensibles de la tienda.
 - **Sin subdominios de administración expuestos**, a diferencia del patrón habitual en hosting compartido.
-

4. Plan de remediación priorizado

#	ACCIÓN	IMPACTO	ES-FUERZO	PLAZO
1	Publicar política de privacidad y enlazarla desde el pie; aviso + consentimiento en los 3 formularios y en el checkout	Alto (legal)	Medio	Inmediato
2	Bloquear enumeración de usuarios (wp-json/wp/v2/users y wp-sitemap-users)	Medio	Bajo	Inmediato
3	2FA y limitación de intentos en wp-login.php	Medio	Bajo	Inmediato
4	Declarar el campo remote_ip en el aviso del formulario o dejar de recogerlo	Medio (legal)	Bajo	1 semana
5	DMARC: añadir rua= , luego p=quarantine ; SPF a -all ; quitar +a +mx ; DKIM a 2048 bits	Medio	Bajo	1 semana
6	Autoalojar Google Fonts; sustituir el iframe de Maps por imagen estática enlazada	Medio (legal)	Bajo	2 semanas
7	Cabeceras: HSTS, CSP, X-Frame-Options, nosniff, Referrer-Policy, COOP	Medio	Bajo	2 semanas
8	Verificar licencia y actualizaciones de Oxygen y Piotnet Forms Pro	Medio	Bajo	2 semanas
9	Auditar la ubicación de los respaldos de All-in-One WP Migration	Alto (si están expuestos)	Bajo	Requiere modo auditoría
10	CAA, DNSSEC, MTA-STS, TLS-RPT	Bajo	Medio	1 mes
11	Ocultar versión de WordPress/WooCommerce y parámetros ?ver=	Bajo	Bajo	1 mes
12	Publicar /.well-known/security.txt	Bajo	Bajo	Cuando se pueda

El punto 1 es el que cambia la exposición legal del cliente. Los puntos 2 y 3 son los que cambian su exposición técnica. El punto 9 puede reordenarlo todo si el respaldo resulta estar accesible.

5. Alcance y límites de este análisis

- **Escaneo pasivo.** Solo se leyó información que el servidor publica por sí mismo: HTML, cabeceras, DNS, Certificate Transparency, robots.txt , el sitemap declarado en él y los en-

dpoints REST anunciados por el propio servidor en su cabecera `Link` . No hubo fuerza bruta, prueba de credenciales, inyección, fuzzing de rutas ni explotación alguna.

- **No se verificó la explotabilidad** de ningún hallazgo.
- **Falta lo que solo un modo auditoría autorizado puede ver:** ubicación de los respaldos de All-in-One WP Migration, `wp-login.php` , archivos de configuración, el flujo real de checkout de WooCommerce, las cookies tras interacción y el comportamiento del formulario al enviarse.
- **Los dos plugins premium** (Oxygen, Piotnet Forms Pro) no son verificables contra el repositorio público de WordPress: su estado de actualización queda sin determinar.
- **El semáforo 21.719 son señales técnicas observables**, no una calificación legal. Corresponde al servicio de Datos Personales de IDATA emitir el juicio de cumplimiento.

Escaneo generado con IDATA Sentinel (modo pasivo) y verificación manual sobre su resultado. Los datos crudos del escaneo están en `out/morenoyca.json` .